# Ce que le site enregistre

**Activité — empreintes, vérification d'une connexion et sel**

BTS SIO 1re année

Cybersécurité

### Objectifs

- Constater les propriétés d'une fonction de hachage avec un outil.
- Vérifier une connexion en comparant des empreintes, sans connaître le mot de passe.
- Expliquer ce qu'apporte le sel quand une base d'empreintes est volée.

### Prérequis

- Le cours du matin : empreinte, vérification, sel, fonction lente.
- La réutilisation des mots de passe et les dictionnaires (12/11).

### Sommaire


| Étape | Contenu |
|---|---|
| Étape 1 | Observer des empreintes (10 min) |
| Étape 2 | Vérifier une connexion (10 min) |
| Étape 3 | Lire une base sans sel (15 min) |
| Étape 4 | Ajouter un sel (10 min) |
| Étape 5 | Trace individuelle (10 min) |


### Consignes

**En binôme, sur poste, 55 minutes.** Chacun rédige ses réponses. IA interdite.

> **Règle.** Les mots de passe de cette fiche sont fictifs. N'entrez **jamais** un de vos vrais mots de passe dans la calculatrice, ni dans aucun site de calcul d'empreinte.

**Calculatrice d'empreinte SHA-256** : elle est disponible sur la page web de cette activité. Sur papier, les empreintes utiles sont données dans les corrigés.

### Étape 1 — Observer des empreintes

**10 minutes.** Avec la calculatrice, calculez l'empreinte de chaque texte et notez ses huit premiers caractères.

| Texte | 8 premiers caractères de l'empreinte |
|---|---|
| `velo` | |
| `Velo` | |
| `velo` suivi d'une espace | |
| Une phrase entière de votre choix | |

1. Recalculez l'empreinte de `velo` : obtenez-vous la même ? Quelle propriété cela montre-t-il ?
2. Comparez `velo` et `Velo`. Quelle propriété le montre ?
3. Combien de caractères compte chaque empreinte, quelle que soit la longueur du texte ?

**À produire :** le tableau, et une propriété nommée pour chaque question.

### Étape 2 — Vérifier une connexion

**10 minutes.** Le site de VéloCité a enregistré, pour le compte `a.petit@exemple.fr`, l'empreinte :

`7c90885eb7f31b380982a02ed1869aa86846054c1f8bc8dadc830de8a500035a`

Trois tentatives de connexion arrivent : `guidon-orage-pomm3`, `Guidon-orage-pomme`, `guidon-orage-pomme`.

1. Pour chaque tentative, calculez l'empreinte et dites si le site accepte la connexion.
2. À quel moment le site a-t-il eu besoin de connaître le mot de passe enregistré ?

**À produire :** la décision du site pour chaque tentative, et la réponse à la question 2.

### Étape 3 — Lire une base sans sel

**15 minutes.** Une ancienne version de l'application stockait des empreintes SHA-256 **sans sel**. Voici un extrait de la table, qui aurait pu être volée.

| Compte | Empreinte enregistrée (début) |
|---|---|
| `l.bernard@exemple.fr` | `ddadc448f590…` |
| `m.durand@exemple.fr` | `f2d81a260dea…` |
| `s.roux@exemple.fr` | `7c90885eb7f3…` |
| `k.morel@exemple.fr` | `f2d81a260dea…` |

1. Sans rien calculer : que peut-on dire de `m.durand` et de `k.morel` ?
2. Calculez les empreintes de `azerty`, `soleil` et `123456`, trois mots de passe parmi les plus courants. Que découvrez-vous ?
3. Le compte `s.roux` a la même empreinte que celle de l'étape 2. Était-ce prévisible ? Pourquoi son mot de passe a-t-il tenu, alors que d'autres n'ont pas tenu ?

**À produire :** les comptes exposés et une phrase qui explique pourquoi.

### Étape 4 — Ajouter un sel

**10 minutes.** La nouvelle version tire un sel au hasard pour chaque compte et hache `sel:mot de passe`.

| Compte | Sel | Mot de passe |
|---|---|---|
| `m.durand@exemple.fr` | `x7Qk` | `azerty` |
| `k.morel@exemple.fr` | `p2Lm` | `azerty` |

1. Calculez les empreintes de `x7Qk:azerty` et de `p2Lm:azerty`. Les deux comptes ont-ils encore la même empreinte ?
2. L'empreinte de `azerty` calculée à l'étape 3 permet-elle encore de repérer ces deux comptes ?
3. Le sel est enregistré dans la base, à côté de l'empreinte. Pourquoi n'est-ce pas grave ?
4. Le sel suffit-il à protéger `azerty` si l'attaquant connaît le sel ? Que faut-il en plus ?

**À produire :** vos réponses, avec les huit premiers caractères des deux empreintes.

### Étape 5 — Trace individuelle

**10 minutes, seul.** Trois phrases, sans regarder la fiche :

1. Comment un site vérifie un mot de passe sans le garder.
2. Pourquoi une base d'empreintes sans sel reste dangereuse pour les mots de passe courants.
3. Ce que le sel et une fonction lente changent pour l'attaquant.

### Vérification avant de terminer

- [ ] Je sais nommer trois propriétés d'une fonction de hachage.
- [ ] J'ai vérifié une connexion par comparaison d'empreintes.
- [ ] Je sais expliquer pourquoi deux empreintes identiques trahissent un même mot de passe.
- [ ] Je sais expliquer le rôle du sel, et pourquoi il n'a pas besoin d'être secret.

# Corrigés

BTS SIO 1re année

**Activité — empreintes, vérification d'une connexion et sel**

Cybersécurité

## Étape 1

| Texte | Empreinte SHA-256 |
|---|---|
| `velo` | `cd1e45e8b94d27b2562ab5ae45b4bff61e2bc89d9ca4ffe117e70aa5ac8ef1eb` |
| `Velo` | `5d1e437e74a365f9b15ce20130505fd6470219dc43c7b884247dae5627b9a7c0` |
| `velo` + espace | `dcb58e1533c6df9657b2ed9fa0e258a751e70f225881ee85cbc55011f95fff5c` |

1. Même empreinte : la fonction est **déterministe**.
2. Une seule lettre change et toute l'empreinte change : **effet avalanche**.
3. Toujours 64 caractères : **taille fixe**.

## Étape 2

| Tentative | Empreinte (début) | Décision |
|---|---|---|
| `guidon-orage-pomm3` | `390e6b8c84ec…` | Refusée |
| `Guidon-orage-pomme` | `b3588843301…` | Refusée |
| `guidon-orage-pomme` | `7c90885eb7f3…` | **Acceptée** |

Jamais : le site compare des empreintes. Il n'a besoin que de celle enregistrée à l'inscription.

## Étape 3

1. Même empreinte : ils ont **le même mot de passe**, sans qu'on sache encore lequel.
2. `azerty` donne `f2d81a260dea…` : `m.durand` et `k.morel` utilisent `azerty`. `soleil` (`e93e24c1b877…`) et `123456` (`8d969eef6eca…`) n'apparaissent pas dans l'extrait. Le mot de passe de `l.bernard` reste inconnu avec ces trois mots seulement, mais une liste plus longue, avec les transformations vues le 12/11 (nom de ville, année, `!`), le trouverait.
3. Oui : c'est la même empreinte que `guidon-orage-pomme`, donc le même mot de passe. Il a tenu parce qu'une phrase de mots tirés au hasard ne figure dans aucune liste de mots courants : impossible de « deviner et comparer ». Le hachage protège bien les mots de passe forts, mal les faibles.

## Étape 4

1. `x7Qk:azerty` donne `0b7ef626e317…`, `p2Lm:azerty` donne `4ebe301aecee…` : les empreintes sont différentes.
2. Non : l'empreinte de `azerty` seul ne correspond à aucune des deux.
3. Le sel n'a pas besoin d'être secret : il rend chaque empreinte unique, ce qui empêche de repérer les doublons et rend inutiles les listes d'empreintes calculées à l'avance.
4. Non : un attaquant qui connaît le sel peut encore essayer les mots courants **compte par compte**. Il faut aussi une fonction **lente** (bcrypt, Argon2) pour que chaque essai coûte cher, et surtout un mot de passe qui n'est dans aucune liste.